

Maestría en Seguridad Informática
Proyecto de Fin de Curso
By Msc. Ing. César Rodríguez Minas

Propuesta de Proyecto Final: Evaluación, Rediseño e Implementación de Seguridad Continua en Aplicaciones Cloud-Native (Web / Móvil)

Curso: Seguridad en Aplicaciones

Institución: Universidad Mariano Gálvez de Guatemala — Maestría en Seguridad Informática.

Ponderación: 20 Puntos Netos

Modalidad: Reto Práctico en Grupos

1. Visión General del Proyecto

El objetivo de este proyecto final es que el estudiante asuma el rol de **Lead Security Architect / DevSecOps Specialist** para realizar un análisis de riesgos exhaustivo, una evaluación de ciberdefensa y el diseño/implementación de controles de ciberseguridad sobre una aplicación crítica integrada a infraestructura Cloud.

El proyecto fusiona el estándar de evaluación por capas y matriz de riesgos (ISO/IEC 27001, STRIDE/DREAD) con el **Ciclo de Vida Continuo de Seguridad de Aplicaciones (Continuous Application Security Lifecycle)**, asegurando que los controles abarquen desde la arquitectura hasta el monitoreo en tiempo de ejecución.

2. Escenarios Prácticos a Seleccionar (Target Applications)

El estudiante debe seleccionar **una** de las siguientes opciones para su desarrollo y evaluación:

Opción A: Aplicación Móvil Banking / Fintech Cloud (Android o iOS)

● **Descripción:** Aplicación móvil conectada a un Backend de Microservicios desplegado en la Nube (AWS / GCP / Azure) a través de un **API Gateway**.

● **Puntos Críticos:** Autenticación biométrica / OAuth2 + PKCE, cifrado de datos en reposo en el dispositivo (Keystore/Keychain), protección contra ingeniería inversa, seguridad en APIs (OWASP API Top 10) y comunicación TLS Pinning.

Opción B: CMS / E-Commerce Web Enterprise Cloud-Native

● **Descripción:** Plataforma Web basada en CMS Open Source (*Drupal, Moodle, Joomla, Ghost*) o E-Commerce (*WooCommerce/Magento*) desplegado en contenedores (Docker / Kubernetes) en infraestructura Cloud con base de datos administrada y CDNs.

● **Puntos Críticos:** OWASP Web Top 10 (SQLi, XSS, CSRF, Broken Access Control), seguridad en complementos/plugins, WAF (Web Application Firewall), Hardening de Servidores e Infraestructura como Código (IaC).

3. Estructura de Fases del Proyecto (Alineadas al Ciclo de Vida Moderno)

```
+-----------------------------------------------------------------------------------------------------+
| CONTINUOUS APPLICATION SECURITY LIFECYCLE                                                           |
+-----------------------------------------------------------------------------------------------------+
| [Fase 1] Planificación & Requisitos ---> Threat Modeling (STRIDE) + ISO 27001                       |
| [Fase 2] Diseño Arquitectónico Cloud ---> API Gateway, Zero Trust, Data Encryption                  |
| [Fase 3] Desarrollo & DevSecOps ---> SAST, SCA, Secure Coding Practices                             |
| [Fase 4] Verificación / Ciberdefensa ---> DAST, Pentesting (Caja Negra/Gris/Blanca)                 |
| [Fase 5] Despliegue & Contenedores ---> IaC Hardening, Container Scanning                           |
| [Fase 6] Operaciones & Ciberseguridad---> WAF, RASP, SIEM, Tratamiento del Riesgo                   |
+-----------------------------------------------------------------------------------------------------+
```

FASE 1: Planificación, Activos e Identificación de Riesgos

1.1 Inventario de Activos de Información (Norma ISO/IEC 27001)

El estudiante deberá estructurar el inventario formal de activos con los siguientes campos obligatorios:

● Identificador & Nombre del Activo

● Proceso Asociado & Descripción

● **Tipo:** Información, Software, Físico, Personal, Servicios, Empresa.

● **Ubicación:** Local / Cloud / Dispositivo Móvil / Repositorio.

● **Valoración Triada CIA :** Clasificación en **Alta (A)**, **Media (M)** o **Baja (B)**.

● Justificación & Criticidad Calculada.

● Propietario, Custodio y Usuarios con Acceso.

1.2 Modelado de Amenazas (STRIDE) y Clasificación (DREAD)

Selección y aplicación de la metodología de evaluación:

● **Análisis STRIDE:** Evaluando *Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege*.

● **Scoring DREAD:** Para cada vulnerabilidad o caso de abuso encontrado:

1.3 Análisis de Riesgos en 7 Capas (Seguridad en Profundidad)

Evaluación obligatoria clasificando hallazgos en las 7 capas de seguridad:

1. **Datos:** Cifrado en reposo/tránsito, enmascaramiento, gestión de claves (KMS).

2. **Aplicación:**

    ○ *a. Código:* Buenas prácticas de programación, sanitización.

    ○ *b. Aplicación:* Lógica de negocio, autenticación, autorización.

    ○ *c. Implementación:* Bibliotecas, dependencias, frameworks.

    ○ *d. Perímetro de Aplicación:* Endpoints de APIs, rutas públicas vs privadas.

3. **Host:** OS Hardening, parches, actualización del runtime/contenedor.

4. **Red Interna:** VPCs, Subredes Privadas, Security Groups, Microsegmentación.

5. **Perímetro Cloud / Red:** Firewalls, DDoS Mitigation, API Gateways, Cloudflare/AWS Shield.

6. **Seguridad Física:** Infraestructura del proveedor Cloud (SLA/Certificaciones SOC2, ISO 27001).

7. **Políticas, Procedimientos y Concientización:** Póliza de contraseñas, DevSecOps policy, gestión de incidentes.



FASE 2: Diseño Arquitectónico Cloud y Requisitos de Seguridad

1. **Diagrama de Arquitectura de Seguridad Cloud:**

    ○ Representación clara del flujo de datos desde el cliente (Web/Móvil) hasta la base de datos cloud.

    ○ Inclusión de **API Gateway**, servicios de identidad (IAM / Cognito / Auth0), WAF y almacenamiento cifrado.

2. **Especificación de Controles:**

    ○ Definición del principio de **Menor Privilegio** en roles IAM.

    ○ Estrategia de cifrado de datos (AES-256 en base de datos, TLS 1.3 en tránsito).

FASE 3: Desarrollo Seguro y Automatización DevSecOps

El proyecto requiere simular o implementar un flujo de trabajo CI/CD automatizado:

1. **Análisis Estático de Código (SAST):** Ejecución de herramientas (ej. SonarQube, Semgrep, Checkmarx) para detectar fallos de codificación antes del despliegue.

2. **Análisis de Dependencias y Composición de Software (SCA):** Escaneo de librerías de terceros (ej. OWASP Dependency-Check, Snyk) en busca de CVEs conocidos.

3. **Prácticas de Codificación Segura:** Demostración de mitigaciones en código fuente (ej. consultas preparadas contra SQLi, sanitización contra XSS, manejo seguro de Tokens JWT).

FASE 4: Implementación de Ciberdefensa

Realización de pruebas ofensivas y defensivas simulando un ataque real:

1. **Pruebas de Penetración - Caja Negra (Black Box):**

    ○ Escaneo externo con herramientas como **OWASP ZAP**, **Burp Suite** o **Nmap**.

    ○ Intento de explotación sin conocimiento previo de credenciales ni código fuente.

2. **Pruebas de Seguridad Basadas en Riesgos - Caja Gris / Blanca (Gray/White Box):**

    ○ Revisión con acceso a arquitectura, APIs y/o código fuente.

    ○ Verificación de la lógica de autenticación, control de acceso roto (BOLA/IDOR en APIs).

3. **Modelado y Ejecución de Casos de Abuso (Abuse Cases):**

    ○ Definición de escenarios donde un atacante abusa de funciones legítimas (ej. *Brute-force en login*, *Bypass de MFA*, *Exfiltración masiva vía API pagination*).

4. **Delimitación del Perímetro del Software:**

    ○ Mapeo de la superficie de ataque expuesta a internet (Endpoints, Webhooks, puertos abiertos).

FASE 5: Despliegue Seguro e Infraestructura Cloud (Release & CloudSec)

1. **Escaneo de Contenedores y Artefactos:**

    ○ Análisis de imágenes Docker/OCI en busca de vulnerabilidades en el SO base (ej. Trivy, Grype).

2. **Hardening de Infraestructura como Código (IaC):**

    ○ Auditoría de scripts Terraform, CloudFormation o Dockerfiles mediante herramientas como **Checkov** o **tfsec** para evitar configuraciones erróneas (ej. S3 buckets públicos, puertos 22 abiertos a 0.0.0.0/0).

FASE 6: Operaciones, Monitoreo y Ciberseguridad

1. **Estrategia de Mitigación y Ciberseguridad:**

    ○ Definición detallada de controles compensatorios para cada riesgo identificado en las fases de ciberdefensa.

    ○ Configuración e integración conceptual o práctica de:

        ■ **WAF (Web Application Firewall):** Reglas para bloquear OWASP Top 10.

■ **RASP / Monitoreo de APIs:** Detección de comportamientos anómalos en tiempo de ejecución.

■ **Gestión de Eventos e Incidentes (SIEM):** Centralización de logs de auditoría.

2. **Tratamiento Formal del Riesgo:**

○ Matriz de decisiones por riesgo: **Aceptar, Eliminar, Evitar, Mitigar o Transferir**.

○ Categorización del riesgo por Tipo (*Software, Seguridad, Técnico, Cloud, etc.*) e Impacto (*Reputacional, Operacional, Financiero, Legal*).

3. **Matriz de Calor (Heatmap):** Gráfica de Probabilidad vs. Impacto antes y después de aplicar controles de mitigación.

4. Matriz de Ponderación del Proyecto (20 Puntos Netos)

Componente a Evaluar	Ponderación	Criterios Principales de Evaluación
1. Análisis de Riesgos y Activos	**4 Puntos**	• Inventario completo de Activos ISO 27001. • Modelado de amenazas STRIDE / Scoring DREAD. • Cobertura explícita de las 7 capas de Seguridad por Profundidad. • Matriz de Calor y Tratamiento del Riesgo.
2. Arquitectura Cloud & DevSecOps	**4 Puntos**	• Diagrama de arquitectura de seguridad (API Gateway, IAM, Cloud).

		• Evidencia de herramientas SAST/SCA integradas. • Análisis de Infraestructura como Código (IaC).
3. Implementación de Ciberdefensa	**4 Puntos**	• Reporte de Pentest Caja Negra (OWASP ZAP/Burp). • Evaluación Caja Gris/Blanca de la app. • Definición de Casos de Abuso y Perímetro.
4. Implementación de Ciberseguridad	**4 Puntos**	• Plan detallado de mitigación técnica por hallazgo. • Propuesta / Configuración de WAF, RASP, Cifrado, SIEM.
5. Informe Técnico & Formato APA	**4 Puntos**	• Cumplimiento estricto del formato UMG (Arial 12, interlineado 1.5, sangrías, estructura formal, referencias APA). • Dictamen final y conclusiones fundamentadas.
TOTAL	**20 Puntos**	

5. Estructura del Informe Final (Entregable Documental)

El informe técnico final debe seguir rigurosamente el esquema requerido:

INFORME GENERAL – OPCIÓN A (Aplicación Móvil Banking / Fintech)

0. Portada

Resumen Ejecutivo

Índice General

1. Selección y Planificación

1.1 Contexto de la Aplicación Móvil
1.2 Objetivos del Proyecto
1.3 Alcance
1.4 Normativas y Estándares
1.5 Definición del Scope Técnico

2. Activos y Riesgos

2.1 Inventario de Activos (ISO 27001)
2.2 Clasificación CIA y Criticidad
2.3 Modelado de Amenazas (STRIDE)
2.4 Clasificación de Riesgos (DREAD)
2.5 Matriz de Riesgos Inicial

3. Evaluación de Seguridad

3.1 Pentesting Caja Negra
3.2 Pentesting Caja Gris / Blanca
3.3 Evaluación de APIs (OWASP API Top 10)
3.4 SAST (Código Móvil y Backend)
3.5 SCA (Dependencias Móviles y Backend)
3.6 Evaluación de Arquitectura Cloud

4. Mitigación y Ciberseguridad

4.1 Rediseño Arquitectónico Cloud Seguro
4.2 Controles de Seguridad Propuestos
4.3 Hardening de Aplicación Móvil
4.4 Hardening de APIs y Microservicios
4.5 Hardening de Infraestructura Cloud
4.6 Implementación de Controles DevSecOps

5. Operaciones y Monitoreo

5.1 WAF
5.2 RASP / Protección en Tiempo de Ejecución
5.3 SIEM / Correlación de Eventos
5.4 Alertas y Dashboards
5.5 Gestión Continua de Vulnerabilidades
5.6 Tratamiento del Riesgo

6. Dictamen y Mejores Prácticas

6.1 Conclusiones
6.2 Recomendaciones Técnicas
6.3 Roadmap de Seguridad Continua
6.4 Lecciones Aprendidas
6.5 Anexos
6.6 Referencias



Maestría en Seguridad Informática
Proyecto de Fin de Curso
By Msc. Ing. César Rodríguez Minas

INFORME GENERAL – OPCIÓN B (CMS / E-Commerce Web)

0. Portada

Resumen Ejecutivo

Índice General

1. Selección y Planificación

1.1 Contexto del CMS / E-Commerce
1.2 Objetivos del Proyecto
1.3 Alcance
1.4 Normativas y Estándares
1.5 Definición del Scope Técnico

2. Activos y Riesgos

2.1 Inventario de Activos (ISO 27001)
2.2 Clasificación CIA y Criticidad
2.3 Modelado de Amenazas (STRIDE)
2.4 Clasificación de Riesgos (DREAD)
2.5 Matriz de Riesgos Inicial

3. Evaluación de Seguridad

3.1 Pentesting Caja Negra
3.2 Pentesting Caja Gris / Blanca
3.3 Evaluación OWASP Web Top 10
3.4 Evaluación de Plugins y Themes
3.5 SAST (Código del CMS / Plugins)
3.6 SCA (Dependencias y Plugins)
3.7 Evaluación de Contenedores y Kubernetes

4. Mitigación y Ciberseguridad

4.1 Rediseño Arquitectónico Cloud Seguro

4.2 Controles de Seguridad Propuestos
4.3 Hardening del CMS
4.4 Hardening de Plugins y Themes
4.5 Hardening de Contenedores
4.6 Hardening de Infraestructura Cloud
4.7 Implementación de Controles DevSecOps

5. Operaciones y Monitoreo

5.1 WAF
5.2 RASP / Protección en Tiempo de Ejecución
5.3 SIEM / Correlación de Eventos
5.4 Alertas y Dashboards
5.5 Gestión Continua de Vulnerabilidades
5.6 Tratamiento del Riesgo

6. Dictamen y Mejores Prácticas

6.1 Conclusiones
6.2 Recomendaciones Técnicas
6.3 Roadmap de Seguridad Continua
6.4 Lecciones Aprendidas
6.5 Anexos
6.6 Referencias

6. Toolkit de Herramientas Recomendadas (Open Source / Free Tier)

Para maximizar el impacto práctico del proyecto sin incurrir en costos elevados, se sugiere el uso de las siguientes herramientas: **Categoria**	**Herramientas Recomendadas**
Threat Modeling	OWASP Threat Dragon, Microsoft Threat Modeling Tool
Pentesting & DAST	OWASP ZAP, Burp Suite Community Edition, Postman (API Security)
SAST (Static Analysis)	SonarQube Community, Semgrep, Bandit (Python), SpotBugs (Java)
SCA (Dependency Check)	OWASP Dependency-Check, Snyk CLI
Container & IaC Security	Trivy, Checkov, tfsec
Cloud & WAF	AWS Free Tier (CloudFront + WAF / API Gateway), Cloudflare Free, ModSecurity